



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Sites: <https://passwordsleakcheck-pa.googleapis.com> <http://localhost:5001> <https://beacons.gcp.gvt2.com> <https://chromewebstore.googleapis.com> <https://clientservices.googleapis.com> <https://update.googleapis.com> <https://content-autofill.googleapis.com> <https://maxcdn.bootstrapcdn.com> <https://optimizationguide-pa.googleapis.com> <https://ajax.googleapis.com> <https://accounts.google.com> <https://www.googleapis.com> <http://localhost:5000> <http://clients2.google.com>

Generated on Mon, 7 Apr 2025 20:28:59

ZAP Version: 2.16.1

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	5
Low	8
Informational	6

Alerts

Name	Risk Level	Number of Instances
CSP: Failure to Define Directive with No Fallback	Medium	2
Content Security Policy (CSP) Header Not Set	Medium	10
Cross-Domain Misconfiguration	Medium	7
Missing Anti-clickjacking Header	Medium	10
Vulnerable JS Library	Medium	2
Cookie No HttpOnly Flag	Low	1
Cookie without SameSite Attribute	Low	2
Cross-Domain JavaScript Source File Inclusion	Low	2
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	9
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	1
Strict-Transport-Security Header Not Set	Low	20
Timestamp Disclosure - Unix	Low	7
X-Content-Type-Options Header Missing	Low	19

Authentication Request Identified	Informational	1
Information Disclosure - Suspicious Comments	Informational	3
Modern Web Application	Informational	1
Re-examine Cache-control Directives	Informational	12
Retrieved from Cache	Informational	7
Session Management Response Identified	Informational	1

Alert Detail

Medium	CSP: Failure to Define Directive with No Fallback
Description	The Content Security Policy fails to define one of the directives that has no fallback. Missing /excluding them is the same as allowing anything.
URL	http://localhost:5000/robots.txt
Method	GET
Attack	
Evidence	default-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:5000/sitemap.xml
Method	GET
Attack	
Evidence	default-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:5000/
Method	GET
Attack	
Evidence	

Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1673999601&target=OPTIMIZATION_TARGET_PAGE_VISIBILITY
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1679317318&target=OPTIMIZATION_TARGET_LANGUAGE_DETECTION
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1696267841&target=OPTIMIZATION_TARGET_OMNIBOX_URL_SCORING
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1728324084&target=OPTIMIZATION_TARGET_OMNIBOX_ON_DEVICE_TAIL_SUGGI
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742223763&target=OPTIMIZATION_TARGET_GEOLOCATION_PERMISSION_PREDI
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742223793&target=OPTIMIZATION_TARGET_NOTIFICATION_PERMISSION_PREDI
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742310213&target=OPTIMIZATION_TARGET_CLIENT_SIDE_PHISHING
Method	GET

Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=240731042075&target=OPTIMIZATION_TARGET_SEGMENTATION_COMPOSE_PRO
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=5&target=OPTIMIZATION_TARGET_PAGE_TOPICS_V2
Method	GET
Attack	
Evidence	
Other Info	
Instances	10
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/CSP/Introducing_Content_Security_Policy https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Cross-Domain Misconfiguration
Description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	http://localhost:5000/sockjs-node/info?t=1744037968589
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:5000/sockjs-node/info?t=1744039367212
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *

Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:5000/sockjs-node/info?t=1744039368707
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://ajax.googleapis.com/ajax/libs/jquery/3.3.1/jquery.min.js
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/css/bootstrap.min.css
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/css/bootstrap.min.css.map
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/js/bootstrap.min.js
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser

Other Info	implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	7
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.
Reference	https://vulncat.fortify.com/en/detail?id=desc.config.dotnet.html5_overly_permissive_cors_policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Medium	Missing Anti-clickjacking Header	
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.	
URL	http://localhost:5000/	
Method	GET	
Attack		
Evidence		
Other Info		
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1673999601&target=OPTIMIZATION_TARGET_PAGE_VISIBILITY	
Method	GET	
Attack		
Evidence		
Other Info		
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1679317318&target=OPTIMIZATION_TARGET_LANGUAGE_DETECTION	
Method	GET	
Attack		
Evidence		
Other Info		
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1696267841&target=OPTIMIZATION_TARGET_OMNIBOX_URL_SCORING	
Method	GET	
Attack		
Evidence		
Other Info		
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1728324084&target=OPTIMIZATION_TARGET_OMNIBOX_ON_DEVICE_TAIL_SUGGESTIONS	

Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742223763&target=OPTIMIZATION_TARGET_GEOLOCATION_PERMISSION_PREDICTION
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742223793&target=OPTIMIZATION_TARGET_NOTIFICATION_PERMISSION_PREDICTION
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742310213&target=OPTIMIZATION_TARGET_CLIENT_SIDE_PHISHING
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=240731042075&target=OPTIMIZATION_TARGET_SEGMENTATION_COMPOSE_PROPOSAL
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=5&target=OPTIMIZATION_TARGET_PAGE_TOPICS_V2
Method	GET
Attack	
Evidence	
Other Info	
Instances	10
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP header. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options

CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	Vulnerable JS Library
Description	The identified library appears to be vulnerable.
URL	https://ajax.googleapis.com/ajax/libs/jquery/3.3.1/jquery.min.js
Method	GET
Attack	
Evidence	/3.3.1/jquery.min.js
Other Info	The identified library jquery, version 3.3.1 is vulnerable. CVE-2020-11023 CVE-2020-11022 CVE-2019-11358 https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/ https://nvd.nist.gov/vuln/detail/CVE-2019-11358 https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/
URL	https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/js/bootstrap.min.js
Method	GET
Attack	
Evidence	/3.3.7/js/bootstrap.min.js
Other Info	The identified library bootstrap, version 3.3.7 is vulnerable. CVE-2018-14041 CVE-2019-8331 CVE-2018-20677 CVE-2018-20676 CVE-2018-14042 CVE-2016-10735 CVE-2024-6484 CVE-2024-6485 https://nvd.nist.gov/vuln/detail/CVE-2024-6485 https://nvd.nist.gov/vuln/detail/CVE-2024-6484 https://github.com/advisories/GHSA-pj7m-g53m-7638 https://github.com/advisories/GHSA-vxmc-5x29-h64v https://github.com/rubysec/ruby-advisory-db/blob/master/gems/bootstrap-sass/CVE-2024-6484.yml https://github.com/twbs/bootstrap/issues/28236 https://github.com/advisories/GHSA-9v3m-8fp8-mj99 https://github.com/twbs/bootstrap/issues/28236 https://www.herodevs.com/vulnerability-directory/cve-2024-6485 https://github.com/twbs/bootstrap/issues/20184 https://www.herodevs.com/vulnerability-directory/cve-2024-6484 https://github.com/advisories/GHSA-ph58-4vrj-w6hr https://github.com/twbs/bootstrap https://github.com/advisories/GHSA-4p24-vmcr-4gqj https://github.com/rubysec/ruby-advisory-db/blob/master/gems/bootstrap/CVE-2024-6484.yml https://nvd.nist.gov/vuln/detail/CVE-2018-20676
Instances	2
Solution	Upgrade to the latest version of the affected library.
Reference	https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
CWE Id	1395
WASC Id	
Plugin Id	10003

Low	Cookie No HttpOnly Flag
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
URL	http://localhost:5001/login
Method	POST
Attack	
Evidence	Set-Cookie: cookie
Other Info	

Instances	1
Solution	Ensure that the HttpOnly flag is set for all cookies.
Reference	https://owasp.org/www-community/HttpOnly
CWE Id	1004
WASC Id	13
Plugin Id	10010

Low	Cookie without SameSite Attribute
Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	http://localhost:5001/login
Method	POST
Attack	
Evidence	Set-Cookie: connect.sid
Other Info	
URL	http://localhost:5001/login
Method	POST
Attack	
Evidence	Set-Cookie: cookie
Other Info	
Instances	2
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://tools.ietf.org/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	Cross-Domain JavaScript Source File Inclusion
Description	The page includes one or more script files from a third-party domain.
URL	http://localhost:5000/
Method	GET
Attack	
Evidence	<script src="https://ajax.googleapis.com/ajax/libs/jquery/3.3.1/jquery.min.js"></script>
Other Info	
URL	http://localhost:5000/
Method	GET
Attack	
Evidence	<script src="https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/js/bootstrap.min.js"></script>
Other Info	
Instances	2

Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
Reference	
CWE Id	829
WASC Id	15
Plugin Id	10017

Low	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	http://localhost:5000/
Method	GET
Attack	
Evidence	X-Powered-By: Express
Other Info	
URL	http://localhost:5000/favicon.ico
Method	GET
Attack	
Evidence	X-Powered-By: Express
Other Info	
URL	http://localhost:5000/manifest.json
Method	GET
Attack	
Evidence	X-Powered-By: Express
Other Info	
URL	http://localhost:5000/robots.txt
Method	GET
Attack	
Evidence	X-Powered-By: Express
Other Info	
URL	http://localhost:5000/sitemap.xml
Method	GET
Attack	
Evidence	X-Powered-By: Express
Other Info	
URL	http://localhost:5000/static/js/bundle.js
Method	GET
Attack	

Evidence	X-Powered-By: Express
Other Info	
URL	http://localhost:5000/static/js/bundle.js.map
Method	GET
Attack	
Evidence	X-Powered-By: Express
Other Info	
URL	http://localhost:5001/login
Method	OPTIONS
Attack	
Evidence	X-Powered-By: Express
Other Info	
URL	http://localhost:5001/login
Method	POST
Attack	
Evidence	X-Powered-By: Express
Other Info	
Instances	9
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/2012/02/shhh-dont-let-your-response-headers.html
CWE Id	497
WASC Id	13
Plugin Id	10037

Low	Server Leaks Version Information via "Server" HTTP Response Header Field
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	https://clientservices.googleapis.com/uma/v2
Method	POST
Attack	
Evidence	scaffolding on HTTPServer2
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/

CWE Id	497
WASC Id	13
Plugin Id	10036

Low	Strict-Transport-Security Header Not Set
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server and a web browser are to interact with it using only secure HTTPS connections (i.e. HTTP layered on top of the TLS/SSL protocol and is specified in RFC 6797.
URL	https://ajax.googleapis.com/ajax/libs/jquery/3.3.1/jquery.min.js
Method	GET
Attack	
Evidence	
Other Info	
URL	https://content-autofill.googleapis.com/v1/pages/ChRDaHJvbWUvMTM1LjAuNzA0OS40MhlgCU35ljnBRbgwEgUN541ADhIFDc5BT HohUbrvDF
Method	GET
Attack	
Evidence	
Other Info	
URL	https://content-autofill.googleapis.com/v1/pages/ChRDaHJvbWUvMTM1LjAuNzA0OS40MhInCV MWjBFoEgUNbdruHRIFDSXwgNASBQ2W_7htITkdpxWGxz37?alt=proto
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1673999601&target=OPTIMIZA
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1679317318&target=OPTIMIZA
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1696267841&target=OPTIMIZA
Method	GET
Attack	
Evidence	
Other Info	

URL	https://optimizationguide-pa.googleapis.com/downloads?name=1728324084&target=OPTIMIZATION_TARGET_OMNIBOX_ON_DEVICE_TAIL_SUGG
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742223763&target=OPTIMIZATION_TARGET_GEOLOCATION_PERMISSION_PRED
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742223793&target=OPTIMIZATION_TARGET_NOTIFICATION_PERMISSION_PRED
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742310213&target=OPTIMIZA
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=240731042075&target=OPTIMIZATION_TARGET_SEGMENTATION_COMPOSE_PRO
Method	GET
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=5&target=OPTIMIZATION_TAR
Method	GET
Attack	
Evidence	
Other Info	
URL	https://beacons.gcp.gvt2.com/domainreliability/upload
Method	POST
Attack	
Evidence	
Other	

Info	
URL	https://chromewebstore.googleapis.com/v2/items/-/storeMetadata:batchGet
Method	POST
Attack	
Evidence	
Other Info	
URL	https://clientservices.googleapis.com/uma/v2
Method	POST
Attack	
Evidence	
Other Info	
URL	https://optimizationguide-pa.googleapis.com/v1:GetModels?key=AlzaSyA2KlwBX3mkFo30om9
Method	POST
Attack	
Evidence	
Other Info	
URL	https://passwordleakcheck-pa.googleapis.com/v1/leaks:lookupSingle
Method	POST
Attack	
Evidence	
Other Info	
URL	https://update.googleapis.com/service/update2/json
Method	POST
Attack	
Evidence	
Other Info	
URL	https://update.googleapis.com/service/update2/json?cup2key=14:gKAMxBgmutL7PklHx5HKhdYAiyvUshZY589L87YpTx0&cup2hreq=0fb5f05d414dfca9fddce89b
Method	POST
Attack	
Evidence	
Other Info	
URL	https://www.googleapis.com/chromewebstore/v1.1/items/verify
Method	POST
Attack	
Evidence	
Other Info	

Instances	20
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Stri
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet https://owasp.org/www-community/Security-Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	https://optimizationguide-pa.googleapis.com/v1:GetModels?key=AlzaSyA2KlwBX3mkFo30om9LUFYQhpqLoa_BNhE
Method	POST
Attack	
Evidence	1673999601
Other Info	1673999601, which evaluates to: 2023-01-18 04:53:21.
URL	https://optimizationguide-pa.googleapis.com/v1:GetModels?key=AlzaSyA2KlwBX3mkFo30om9LUFYQhpqLoa_BNhE
Method	POST
Attack	
Evidence	1679317318
Other Info	1679317318, which evaluates to: 2023-03-20 18:01:58.
URL	https://optimizationguide-pa.googleapis.com/v1:GetModels?key=AlzaSyA2KlwBX3mkFo30om9LUFYQhpqLoa_BNhE
Method	POST
Attack	
Evidence	1696267841
Other Info	1696267841, which evaluates to: 2023-10-02 22:30:41.
URL	https://optimizationguide-pa.googleapis.com/v1:GetModels?key=AlzaSyA2KlwBX3mkFo30om9LUFYQhpqLoa_BNhE
Method	POST
Attack	
Evidence	1728324084
Other Info	1728324084, which evaluates to: 2024-10-07 23:01:24.
URL	https://optimizationguide-pa.googleapis.com/v1:GetModels?key=AlzaSyA2KlwBX3mkFo30om9LUFYQhpqLoa_BNhE
Method	POST
Attack	
Evidence	1742223763
Other Info	1742223763, which evaluates to: 2025-03-17 20:02:43.

URL	https://optimizationguide-pa.googleapis.com/v1:GetModels?key=AlzaSyA2KlwBX3mkFo30om9LUFYQhpgLoa_BNhE
Method	POST
Attack	
Evidence	1742223793
Other Info	1742223793, which evaluates to: 2025-03-17 20:03:13.
URL	https://optimizationguide-pa.googleapis.com/v1:GetModels?key=AlzaSyA2KlwBX3mkFo30om9LUFYQhpgLoa_BNhE
Method	POST
Attack	
Evidence	1742310213
Other Info	1742310213, which evaluates to: 2025-03-18 20:03:33.
Instances	7
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:5000/
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their declared content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5000/favicon.ico
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their declared content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5000/manifest.json
Method	GET
Attack	
Evidence	
Other	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their declared content type. At "High" threshold this scan rule will not alert on client or server error responses.

Info	content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5000/sockjs-node/info?t=1744037968589
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5000/sockjs-node/info?t=1744039367212
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5000/sockjs-node/info?t=1744039368707
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5000/static/js/bundle.js
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5000/static/js/bundle.js.map
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1673999601&target=OPTIMIZATION_TARGET_PAGE_VISIBILITY
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1679317318&target=OPTIMIZATION_TARGET_LANGUAGE_DETECTION
Method	GET

Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1696267841&target=OPTIMIZATION_TARGET_OMNIBOX_URL_SCORING
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1728324084&target=OPTIMIZATION_TARGET_OMNIBOX_ON_DEVICE_TAIL_SUGGESTIONS
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742223763&target=OPTIMIZATION_TARGET_GEOLOCATION_PERMISSION_PREDICTION
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742223793&target=OPTIMIZATION_TARGET_NOTIFICATION_PERMISSION_PREDICTION
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742310213&target=OPTIMIZATION_TARGET_CLIENT_SIDE_PHISHING
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://optimizationguide-pa.googleapis.com/downloads?name=240731042075&target=OPTIMIZATION_TARGET_SEGMENTATION_COMPOSE_PROPOSALS
Method	GET
Attack	
Evidence	

Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://optimizationguide-pa.googleapis.com/downloads?name=5&target=OPTIMIZATION_TARGET_PAGE_TOPICS_V2
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5001/login
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://clientservices.googleapis.com/uma/v2
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their intended content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	19
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/default.aspx?linkId=8808765 https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://localhost:5001/login
Method	POST
Attack	
Evidence	password
Other	userParam=username userValue=admin passwordParam=password referer=http://localhost:

Info	5000/
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://localhost:5000/static/js/bundle.js
Method	GET
Attack	
Evidence	from
Other Info	The following pattern was used: <code>\bFROM\b</code> and was detected in likely comment: <code>"//inherit from previous dispose call"</code> , see evidence field for the suspicious comment/snippet.
URL	https://ajax.googleapis.com/ajax/libs/jquery/3.3.1/jquery.min.js
Method	GET
Attack	
Evidence	username
Other Info	The following pattern was used: <code>\bUSERNAME\b</code> and was detected in likely comment: <code>"//,It={},Wt={},\$t="*".concat(""),Bt=r.createElement("a");Bt.href=Ct.href;function Ft(e){return function(t,n){"string"!=typeof "</code> , see evidence field for the suspicious comment/snippet.
URL	http://localhost:5000/
Method	GET
Attack	
Evidence	from
Other Info	The following pattern was used: <code>\bFROM\b</code> and was detected in likely comment: <code>"<!-- Notice the use of in the tags above. It will be replaced with the URL of the `public` folder during the build"</code> , see evidence field for the suspicious comment/snippet.
Instances	3
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://localhost:5000/
Method	GET
Attack	
Evidence	<code><script src="https://ajax.googleapis.com/ajax/libs/jquery/3.3.1/jquery.min.js"></script></code>
Other	No links have been found while there are scripts, which is an indication that this is a modern

Info	web application.
Instances	1
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxy to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://content-autofill.googleapis.com/v1/pages/ChRDaHJvbWUvMTM1LjAuNzA0OS40MhlgCU35ljnBRbgwEgUN541ADhIFDc5BTHohUbrvDFalt=proto
Method	GET
Attack	
Evidence	private,max-age=604800
Other Info	
URL	https://content-autofill.googleapis.com/v1/pages/ChRDaHJvbWUvMTM1LjAuNzA0OS40MhInCVMWjBFoEgUNbdruHRIFDSXwgNASBQ2W_7htITkdpXWGxz37?alt=proto
Method	GET
Attack	
Evidence	private,max-age=604800
Other Info	
URL	https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/css/bootstrap.min.css.map
Method	GET
Attack	
Evidence	public, max-age=31919000
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1673999601&target=OPTIMIZATION_TARGET_PAGE_VISIBILITY
Method	GET
Attack	
Evidence	public, max-age=86400
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1679317318&target=OPTIMIZATION_TARGET_LANGUAGE_DETECTION
Method	GET
Attack	
Evidence	public, max-age=86400
Other Info	

URL	https://optimizationguide-pa.googleapis.com/downloads?name=1696267841&target=OPTIMIZATION_TARGET_OMNIBOX_URL_SCORING
Method	GET
Attack	
Evidence	public, max-age=86400
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1728324084&target=OPTIMIZATION_TARGET_OMNIBOX_ON_DEVICE_TAIL_SUGGI
Method	GET
Attack	
Evidence	public, max-age=86400
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742223763&target=OPTIMIZATION_TARGET_GEOLOCATION_PERMISSION_PREDI
Method	GET
Attack	
Evidence	public, max-age=86400
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742223793&target=OPTIMIZATION_TARGET_NOTIFICATION_PERMISSION_PREDI
Method	GET
Attack	
Evidence	public, max-age=86400
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=1742310213&target=OPTIMIZATION_TARGET_CLIENT_SIDE_PHISHING
Method	GET
Attack	
Evidence	public, max-age=86400
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=240731042075&target=OPTIMIZATION_TARGET_SEGMENTATION_COMPOSE_PRO
Method	GET
Attack	
Evidence	public, max-age=86400
Other Info	
URL	https://optimizationguide-pa.googleapis.com/downloads?name=5&target=OPTIMIZATION_TARGET_PAGE_TOPICS_V2
Method	GET
Attack	
Evidence	public, max-age=86400

Other Info	
Instances	12
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immu
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015

Informational	Retrieved from Cache
Description	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://ajax.googleapis.com/ajax/libs/jquery/3.3.1/jquery.min.js
Method	GET
Attack	
Evidence	Age: 359255
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://ajax.googleapis.com/ajax/libs/jquery/3.3.1/jquery.min.js
Method	GET
Attack	
Evidence	Age: 360674
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/css/bootstrap.min.css
Method	GET
Attack	
Evidence	Age: 513603
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/css/bootstrap.min.css
Method	GET
Attack	
Evidence	Age: 515002
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/css/bootstrap.min.css.map
Method	GET
Attack	

Evidence	Age: 1004452
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/js/bootstrap.min.js
Method	GET
Attack	
Evidence	Age: 1614336
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/js/bootstrap.min.js
Method	GET
Attack	
Evidence	Age: 1615735
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
Instances	7
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://tools.ietf.org/html/rfc7234 https://tools.ietf.org/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	
WASC Id	
Plugin Id	10050

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://localhost:5001/login
Method	POST
Attack	
Evidence	s%3A7qFn1NLM2rpPYJuQAn-5qpk4dBteXtkZ. 4LotZQxBgXQpAki6lojlrTyNLmNKsdMRj7JR1kqrirl
Other Info	cookie:connect.sid
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.

Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id
CWE Id	
WASC Id	
Plugin Id	10112